

# KORE

## Auditoria do Backoffice (/admin)

Revisão profunda do painel administrativo: bugs, segurança, escala, gaps e inovações.

Documento interno · revisão técnica · Junho de 2026

### Leitura honesta

O /admin está **sólido e funcional** (9 módulos, RBAC, auditoria, exclusão LGPD). Mas, por ter sido construído rápido, carrega três dívidas a tratar antes de escalar: (1) **escala** — listas sem paginação e contagens com teto fixo; (2) **segurança/trilha** — auditoria sem IP/estado-anterior e exclusão liberada a 'admin'; (3) **profundidade** — a ficha do usuário e o SAC ainda são rasos para suporte real. E há um salto claro de valor: tornar o painel **proativo e com IA**, em vez de só exibir números.

## BUGS / CORRETUDE

### AD01 — Sem paginação nas listas

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** Usuários, Auditoria, Financeiro e Conteúdo cortam em N registros (ex.: 25/200) sem 'próxima página'. Conforme a base cresce, você só vê os primeiros.

**Recomendação:** Paginação server-side (range + botões de página ou 'carregar mais').

### AD02 — Busca quebra com caractere especial

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** A busca de usuários usa .or(ilike) — se o termo tiver vírgula ou parêntese, o filtro do PostgREST quebra e a busca falha.

**Recomendação:** Sanitizar/escapar o termo antes de montar o filtro.

### AD03 — Teto fixo nas contagens

|            |       |
|------------|-------|
| Severidade | Baixa |
|------------|-------|

**Evidência:** KPIs usam listUsers(perPage 1000) e a Análise conta distinto com limite de 10.000 linhas. Acima disso, subnotifica.

**Recomendação:** Pagar o listUsers e mover as contagens para SQL agregado (RPC) quando escalar.

### AD04 — Rótulo 'Suspendo' depende do Supabase

|            |           |
|------------|-----------|
| Severidade | Verificar |
|------------|-----------|

**Evidência:** O estado Suspendo/Ativo na ficha lê banned\_until do getUserById; se a versão do Supabase não retornar esse campo, o rótulo fica sempre 'Ativo' (a AÇÃO de suspender funciona).

**Recomendação:** Confirmar no ambiente; se necessário, persistir um status próprio em perfis.

### AD05 — Telemetria com ruído

|            |       |
|------------|-------|
| Severidade | Baixa |
|------------|-------|

**Evidência:** session\_started dispara em todo evento SIGNED\_IN (inclui refresh de token), inflando a contagem de eventos.

**Recomendação:** Disparar só em login real / deduplicar por sessão.

### AD06 — 'Vínculos (triângulo)' conta bruto

|            |       |
|------------|-------|
| Severidade | Baixa |
|------------|-------|

**Evidência:** O KPI conta todas as linhas de vínculos, inclusive inativas.

**Recomendação:** Filtrar ativo=true ou renomear o rótulo.

## SEGURANÇA

### AD07 — Trilha de auditoria incompleta

|            |      |
|------------|------|
| Severidade | Alta |
|------------|------|

**Evidência:** O audit\_log grava só o 'depois' (corpo da requisição) — não grava o IP nem o estado ANTES da ação. Para trilha LGPD/forense séria, falta.

**Recomendação:** Registrar IP (x-forwarded-for) e o 'antes' nas ações de suspender/excluir/mudar papel.

## AD08 — Exclusão permitida a 'admin'

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** A exclusão de usuário (irreversível) é permitida ao papel admin, não só super\_admin.

**Recomendação:** Restringir a exclusão a super\_admin.

## AD09 — Cliente service-role sem 'server-only'

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** supabaseAdmin usa a SERVICE\_ROLE\_KEY; hoje só é importado em rotas de servidor, mas não há trava. Se um dia for importado num client component, quebra/expõe risco.

**Recomendação:** Adicionar import 'server-only' no topo de supabaseAdmin.ts.

## AD10 — Rotas admin sem rate-limit

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** O projeto tem \_rate-limit.ts, mas as rotas /api/admin não usam. Endpoints administrativos ficam sem proteção contra abuso.

**Recomendação:** Aplicar o rate-limit nas rotas admin.

## AD11 — Lista de admins visível a qualquer admin

|            |       |
|------------|-------|
| Severidade | Baixa |
|------------|-------|

**Evidência:** A rota da Equipe (GET) retorna nomes/e-mails/papéis para qualquer admin logado.

**Recomendação:** Restringir a leitura a super\_admin/admin se quiser menor privilégio.

# GAPS DE FUNCIONALIDADE

## AD12 — Ficha do usuário não mostra os dados dele

|            |      |
|------------|------|
| Severidade | Alta |
|------------|------|

**Evidência:** A ficha tem perfil + conta + nº de vínculos + assinatura, mas não mostra a ATIVIDADE: quantos treinos/sono/registros, última atividade. Suporte precisa disso.

**Recomendação:** Agregar contagens por tabela e 'último registro em...' na ficha.

## AD13 — SAC incompleto

|            |      |
|------------|------|
| Severidade | Alta |
|------------|------|

**Evidência:** Hoje só muda o status do ticket. Falta o detalhe/conversa do ticket — e, principalmente, não existe fluxo no app para o usuário ABRIR um chamado (a tabela fica vazia).

**Recomendação:** Criar abertura de ticket no app + tela de detalhe/resposta no admin.

## AD14 — Sem exportação (CSV)

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** Não há como exportar usuários ou financeiro para planilha.

**Recomendação:** Botão de export CSV nas listas.

## AD15 — Auditoria sem filtros

|            |       |
|------------|-------|
| Severidade | Média |
|------------|-------|

**Evidência:** A tela lista as 200 ações mais recentes, sem filtro por admin, tipo de ação ou período.

**Recomendação:** Filtros + paginação na Auditoria.

### AD16 — Consentimento LGPD não capturado

|                   |              |
|-------------------|--------------|
| <b>Severidade</b> | <b>Média</b> |
|-------------------|--------------|

**Evidência:** O painel de consentimentos existe mas fica sempre vazio porque o cadastro não captura consentimento (pendência F26 da auditoria do app).

**Recomendação:** Capturar consentimento no signup e gravar em consentimentos.

### AD17 — Sem filtro de período

|                   |              |
|-------------------|--------------|
| <b>Severidade</b> | <b>Baixa</b> |
|-------------------|--------------|

**Evidência:** Cockpit e Análise usam janelas fixas (7/14/30 dias), sem seletor.

**Recomendação:** Seletor de período.

### AD18 — /admin não é responsivo

|                   |              |
|-------------------|--------------|
| <b>Severidade</b> | <b>Baixa</b> |
|-------------------|--------------|

**Evidência:** Sidebar fixa de 220px + layout flex; no celular fica espremido.

**Recomendação:** Colapsar a sidebar no mobile (menu hambúrguer).

## INOVAÇÕES (onde o /admin pode ir além)

### AD19 — Cockpit proativo

Em vez de só mostrar números, gerar alertas automáticos: queda de MRR, pico de churn, fila de SAC crescendo, atletas inativos há X dias. Alinha com a própria tese do produto ('triagem proativa').

### AD20 — Admin com IA

Vocês já têm o SDK da Anthropic: consulta em linguagem natural sobre os dados ('quantos atletas inativos há 30 dias?') e um resumo executivo semanal gerado automaticamente.

### AD21 — Digest semanal por e-mail

Usando o Resend (já configurado): um e-mail semanal para os sócios com MRR, crescimento, churn e SAC — sem ninguém precisar abrir o painel.

### AD22 — 'Ver como usuário' (auditado)

Impersonar um usuário (somente leitura, registrado na auditoria) acelera muito o suporte.

### AD23 — Eventos críticos em tempo real

Disparar para Slack/WhatsApp eventos importantes: novo cadastro de profissional, churn, ticket urgente.

### AD24 — Coortes de retenção (quando amadurecer)

A C1 do plano — retenção D1/D7/D30 — passa a valer assim que a telemetria acumular histórico.

## Plano de ação sugerido (ordem)

| Onda                            | Itens                                                                                               | Por quê                                                        |
|---------------------------------|-----------------------------------------------------------------------------------------------------|----------------------------------------------------------------|
| 1 · Segurança e trilha          | AD07 (IP/antes na auditoria), AD08 (exclusão só super_admin), AD09 (server-only), AD10 (rate-limit) | Baixo esforço, fecha risco antes de abrir acesso a mais admins |
| 2 · Escala                      | AD01 (paginação), AD02 (busca segura), AD03 (contagens)                                             | Evita o painel 'mentir' conforme a base cresce                 |
| 3 · Profundidade de suporte     | AD12 (dados na ficha), AD13 (SAC completo), AD14 (export), AD15 (filtros)                           | Torna o admin útil para operar de verdade                      |
| 4 · Inovação                    | AD19 (alertas proativos), AD20 (IA), AD21 (digest semanal)                                          | Salto de valor: painel que avisa e resume, não só mostra       |
| 5 · Quando houver dados/decisão | AD24 (coortes), e a cobrança (provedor) — Fases A/B                                                 | Dependem de tempo de uso e da sua escolha de provedor          |

### Recomendação de uma frase

Antes de mais features ou da cobrança, gaste uma onda curta em **segurança da trilha + paginação** (Ondas 1 e 2) — é barato e protege o que já existe. Depois, o maior salto não é mais um módulo: é tornar o painel **proativo e com IA**.